



PANDUAN

PENANGANAN INSIDEN

SERANGAN

PHISING

Gov-CSIRT
Indonesia

DEPUTI BIDANG KEAMANAN
SIBER DAN SANDI PEMERINTAHAN
DAN PEMBANGUNAN MANUSIA

BADAN SIBER DAN SANDI NEGARA



VERSI DOKUMEN

No	Tanggal	Versi Dokumen	Oleh	Keterangan
1	Desember 2018	Versi 0	Deputi III	-
2	Maret 2025	Versi 1	Deputi III	-



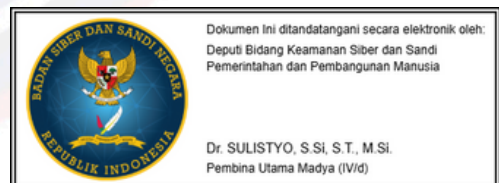
KATA PENGANTAR

Puji syukur kehadiran Allah SWT, atas segala limpahan rahmat, nikmat serta karunia-Nya yang tak ternilai dan tak dapat dihitung sehingga kami dapat menyelesaikan penyusunan “**Panduan Penanganan Insiden Serangan Phising**”. Panduan ini disusun dalam rangka memberikan acuan bagi pihak yang berkepentingan dalam penanganan insiden serangan Phising. Panduan ini berisikan langkah-langkah yang harus diambil apabila terjadi serangan Phising, yang dimulai dari tahap persiapan sampai dengan tahap pembuatan laporan dari penanganan serangan. Panduan ini tentu saja masih banyak kekurangan dan masih jauh dari kesempurnaan karena keterbatasan ilmu dan referensi kami. Untuk itu, kami selalu berusaha melakukan evaluasi dan perbaikan secara berkala agar bisa mencapai hasil yang lebih baik lagi.

Akhir kata, kami ucapkan terima kasih kepada segala pihak yang telah membantu dalam penyusunan panduan ini.

Depok, Maret 2025

Deputi Bidang Keamanan Siber dan Sandi
Pemerintahan dan Pembangunan Manusia,



Dr. Sulistyo, S.Si., S.T., M.Si.

DAFTAR ISI

VERSI DOKUMEN	1
KATA PENGANTAR	2
DAFTAR ISI	3
PANDUAN PENANGANAN INSIDEN SERANGAN PHISHING	4
1. PENDAHULUAN	4
2. TUJUAN	4
3. RUANG LINGKUP	4
4. PROSEDUR PENANGANAN SERANGAN PHISHING	4
4.1. Persiapan	5
4.2. Identifikasi	6
4.3. <i>Containment</i>	6
4.4. <i>Eradication</i>	7
4.5. Pemulihan	7
4.6. Tindak Lanjut	7

PANDUAN PENANGANAN INSIDEN SERANGAN PHISHING

1. PENDAHULUAN

Serangan **phishing** adalah serangan yang dilakukan untuk menipu /memancing korban agar mau mengklik tautan serta menginput informasi kredensial seperti **username** dan **password**. Cara kerja phishing umumnya dilakukan melalui penggunaan **email** palsu mengatasnamakan **admin**, atau melalui situs web palsu yang sangat mirip dengan situs web yang asli.

2. TUJUAN

Secara umum, tujuan panduan ini dimaksudkan untuk membantu organisasi memahami tentang penanganan serangan **phishing**. Sedangkan secara khusus adalah sebagai berikut:

- Melakukan pengumpulan informasi yang akurat;
- Meminimalisir dampak dari serangan siber yang terjadi;
- Mencegah adanya serangan lanjutan dan mencegah kerusakan agar tidak lebih meluas.

3. RUANG LINGKUP

Panduan ini berisi langkah-langkah yang harus diambil apabila terjadi serangan **phishing**, yang dimulai dari tahap persiapan sampai dengan tahap pembuatan laporan dari penanganan serangan. Panduan ini dapat dijadikan acuan bagi semua individu atau tim (**administrator**, pengelola TI, tim respon insiden keamanan komputer) yang bertanggung jawab untuk mencegah, mempersiapkan atau menangani serangan **phishing**.

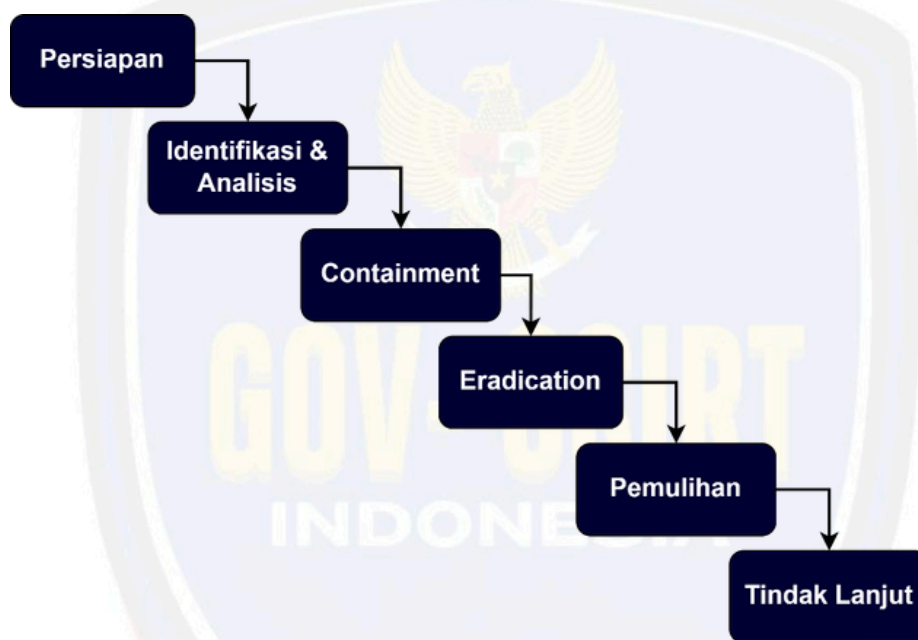
4. PROSEDUR PENANGANAN SERANGAN PHISHING

Penanganan serangan phishing ditujukan untuk mencapai hal-hal sebagai berikut:

- Mengumpulkan informasi sebanyak mungkin tentang serangan **phishing**;

- b. Menghalangi atau mencegah eskalasi kerusakan yang disebabkan oleh serangan tersebut;
- c. Mengumpulkan bukti terkait serangan **phishing**;
- d. Mengambil langkah-langkah proaktif untuk mengurangi kemungkinan terjadinya serangan **phishing** di masa depan.

Supaya tujuan di atas dapat terlaksana dengan baik, maka penanganan terhadap serangan **phishing** dilakukan dalam beberapa tahap sebagai berikut:



Gambar 1. Tahap Penanganan Serangan Phising

4.1. Persiapan

Tujuan tahap persiapan pada penanganan serangan phishing adalah untuk membangun kontak, menentukan prosedur dan mengumpulkan informasi serangan.

Tahap persiapan penanganan serangan phishing, dilakukan dengan prosedur sebagai berikut:

- a) Membuat daftar semua domain sah yang dimiliki organisasi;
- b) Mempersiapkan satu buah halaman website untuk memperingatkan pengguna tentang terjadinya serangan phishing;
- c) Mempersiapkan formulir untuk informasi laporan penyalahgunaan domain.

- d) Membangun kontak dengan pihak-pihak terkait, seperti perusahaan hosting, penyedia domain, penyedia jasa email, Gov-CSIRT;
- e) Meningkatkan kesadaran terhadap serangan phishing, diantaranya :
 - Tidak mengklik link yang mencurigakan;
 - Tidak memasukan username dan password pada situs web yang alamat web nya meragukan;
 - Merubah penulisan alamat email yang dipublish, dari bentuk @ menjadi “at” atau dalam bentuk gambar, untuk menghindari menjadi target email phishing;
 - Menggunakan Anti Virus yang memiliki fitur Anti Phising.

4.2. Identifikasi

Tujuan dari proses identifikasi adalah untuk mendeteksi adanya insiden serangan phishing, menentukan ruang lingkup, dan melibatkan pihak-pihak yang tepat dalam menangani serangan phishing. Tahap identifikasi penanganan serangan phishing adalah sebagai berikut:

- a. Memonitor **email**, **social media**, web **forms** dsb pada Organisasi untuk mencari informasi **Phising**;
- b. Memeriksa **URL phishing** dan **hyperlink** yang mencurigakan menggunakan www.virustotal.com, www.urlvoid.com, serta www.phishtank.com;
- c. Melibatkan pihak yang tepat terkait serangan **phishing**. Agar bisa segera di lakukan **takedown** terhadap web **phishing**. Seperti perusahaan **hosting**, penyedia domain, penyedia jasa **email**, Nasional CERT;
- d. Mengumpulkan bukti bukti terkait adanya serangan **phishing**. Contohnya **screenshot** halaman web yang terdampak.

4.3. Containment

Setelah dipastikan bahwa memang benar telah terjadi serangan phishing, maka dilakukan proses mitigasi serangan, agar tidak terjadi kerusakan lebih dalam.

Prosedur yang dilakukan pada tahap ini adalah:

- a. Menyebarkan URL phishing dan konten dari email phishing pada pihak spam-reporting website, misalnya www.phishtank.com;

- b. Menginformasikan serangan phishing kepada pengguna, agar pengguna mengetahui dan tidak terkena dampak dari serangan tersebut;
- c. Memeriksa source code dari website phishing, jika menggunakan gambar dari website yang anda miliki, anda dapat mengganti gambar dengan tampilan “PHISING WEBSITE”.

4.4. **Eradication**

Proses ini bertujuan untuk mengambil tindakan dalam menghentikan serangan **phishing**. Prosedur untuk melakukan proses ini dapat dilakukan dengan cara berikut:

- a. Jika halaman **phishing** di **hosting** di situs web yang telah disusupi, maka hubungi pemilik dari **website** tersebut, agar halaman **phishing** dihapus dan dilakukan **update security**;
- b. Untuk percepatan penanganan, hubungi perusahaan **hosting** dengan mengirim **email** berisikan informasi **phishing**, serta lakukan kontak telepon perusahaan **hosting** yang tersedia;
- c. Menghubungi perusahaan **hosting** untuk melakukan **takedown** /penutupan alamat **website** palsu;
- d. Jika **takedown** terlalu lama, maka hubungi Nasional CERT untuk mengontak CERT lokal yang berada di negara tersebut untuk membantu proses **takedown**.

4.5. **Pemulihan**

Pemulihan merupakan tahap untuk mengembalikan seluruh sistem bekerja normal seperti semula. Prosedur yang dapat dilakukan sebagai berikut:

- a. Memastikan bahwa halaman **website** penipuan sudah tidak dapat diakses;
- b. Tetap Memantau URL palsu, untuk memastikan URL palsu tersebut tidak dapat diakses;
- c. Menghapus halaman peringatan dari **website**.

4.6. **Tindak Lanjut**

Tahap ini adalah fase di mana semua dokumentasi kegiatan yang dilakukan dicatat sebagai referensi untuk di masa mendatang. Tujuan dari tahap ini adalah untuk:

- a. Pelaporan, membuat laporan mengenai langkah-langkah dan hasil yang telah didapatkan pada penanganan serangan phising;
- b. Mengambil pelajaran dan membuat rekomendasi untuk mencegah terjadi lagi.

Prosedur yang dapat dilakukan adalah sebagai berikut:

- a. Menyempurnakan langkah-langkah respon, prosedur penanganan serangan yang diambil selama insiden agar kedepannya dapat menangani insiden secara lebih cepat dan efisien;
- b. Memperbaharui daftar kontak yang dimiliki, disertai catatan cara paling efektif untuk menghubungi setiap pihak yang terlibat;
- c. Berkolaborasi dengan tim hukum jika diperlukan tindakan hukum;
- d. Membuat dokumentasi dan laporan terkait penanganan serangan Phising;
- e. Membuat evaluasi dan rekomendasi.





GovCSIRT Indonesia

*Jl. Raya Muchtar No.70, Bojongsari Lama, Kec.
Bojongsari, Kota Depok, Jawa Barat 16516
email: govcsirt@bssn.go.id
telegram: [govcsirt_id](https://t.me/govcsirt_id)
whatsapp: +6285123123940*